Indice

1. Resumen ejecutivo y dictamen 2

2. Alcance, metodo y estado verificado 2

3. Reproducibilidad por repositorio (Fase A) 3

4. Pruebas E2E bidireccionales (Fase C) 4

5. Seguridad funcional (Fase E) 4

6. Credenciales, historial Git y rotacion (Fase D) 5

7. Defectos encontrados y correcciones efectuadas (Fase H) 6

8. Persistencia, backup y recuperacion (Fase F) 7

9. Preparacion de produccion y criterios de aceptacion (Fase G) 7

10. Bloqueos, pasos del propietario y declaracion final 8

Anexo A. Inventario de evidencias 8

1. Resumen ejecutivo y dictamen

Esta campana ejecuto una prueba integral, exhaustiva y basada en evidencia sobre los tres repositorios del ecosistema ALBRA8: CRM-ALBRA, WHATSPOWER y WHATSPOWER-ULTRA. A diferencia de auditorias previas de caracter documental, todas las comprobaciones de esta campana se ejecutaron realmente: clonacion limpia desde GitHub, instalacion con lockfile congelado, suites oficiales de tests completas, y una bateria E2E de extremo a extremo con instancias reales de los tres servicios corriendo simultaneamente sobre bases de datos SQLite efimeras con datos 100% sinteticos. No se envio ningun mensaje real de WhatsApp, no se activo ninguna campana y no se toco ningun dato real.

38 + 1	390/390	41/41	3/3
pruebas E2E superadas (+1 rechazo controlado), 0 fallos	tests vitest de CRM-ALBRA (42 ficheros)	suites nativas WP (22+19) + 9 regresiones nuevas	commits publicados verificados contra GitHub

DICTAMEN: INTEGRATION VERIFIED - PRODUCTION BLOCKED. La integracion entre los tres componentes esta demostrada con evidencia ejecutable y los controles de seguridad obligatorios funcionan. El bloqueo de produccion es exclusivamente de credenciales y autorizacion: el PAT de GitHub expuesto no tiene revocacion confirmada, tres secretos operativos requieren rotacion coordinada, la clave NVIDIA sigue recuperable en el historial Git, las correcciones de seguridad desarrolladas en esta campana estan sin publicar (pendientes de autorizacion) y no existe ninguna ejecucion de pruebas en el entorno productivo real.

Durante la campana se detectaron tres defectos de seguridad reales en el codigo publicado: dos mecanismos fail-open por secretos con valores por defecto hardcodeados en WHATSPOWER y ULTRA, y una corrupcion de orden temporal en la base de datos conversacional de WHATSPOWER. Los tres fueron corregidos en el arbol de trabajo local con regresiones automatizadas que los demuestran, y las suites completas fueron re-ejecutadas permaneciendo en verde. Los cambios permanecen sin commit y sin push esperando la autorizacion del propietario, con los diffs completos entregados como evidencia.

2. Alcance, metodo y estado verificado

El alcance fue estrictamente limitado a los tres repositorios autorizados. El entorno anterior habia sido reciclado, por lo que la campana partio de clonaciones limpias desde GitHub sin credenciales (lectura anonima) y sin reutilizar el PAT comprometido. Los tres SHAs esperados coinciden exactamente con los heads remotos de main, sin cambios posteriores a la publicacion. Las ramas remotas ajenas de CRM-ALBRA permanecieron intactas y no se realizaron operaciones de fuerza en ningun momento.

Repositorio	SHA esperado	SHA real en origin/main	Coincide	Cambios posteriores
CRM-ALBRA	9b32591	9b32591aa73fc3c07c450509e1159de1a12354ab	SI	Ninguno

Repositorio	SHA esperado	SHA real en origin/main	Coincide	Cambios posteriores
WHATSPOWER	db0d088	db0d0883caca392ffe92ab65010dd6153c44a0df	SI	Ninguno
WHATSPOWER-ULTRA	08a0bb3	08a0bb3986912dba3faa49f056317cbfc0042f1f	SI	Ninguno

Tabla 1. Verificacion de SHAs remotos contra GitHub (27 de octubre de 2026).

La distribucion de responsabilidades se verifico sin alterarla: CRM-ALBRA actua como fuente de verdad de datos con interfaces autenticadas y aislamiento por organizacion; WHATSPOWER gestiona la conversacional entrante y transmite al CRM mediante su cliente HTTP real; ULTRA gestiona campanas salientes respetando autenticacion, deduplicacion, limites horarios y barreras anti-envio. Ninguna prueba requiero modificar esa distribucion para pasar.

3. Reproducibilidad por repositorio (Fase A)

Cada repositorio se instalo siguiendo su lockfile congelado y se ejecutaron sus comandos oficiales de validacion. En CRM-ALBRA el camino oficial es bun (el CI usa bun.lock); el package-lock.json comentido esta desincronizado y npm ci lo rechaza, un defecto de higiene documentado sin corregir para no alterar lockfiles solo para poner en verde. El lint de CRM falla por artefactos de recuperacion commiteados (carpeta crm_albra_mirrored, 267 ficheros y 15 MB), no por codigo de aplicacion. El build de produccion compilo en 23.2 s pero fue interrumpido por el limite de memoria del sandbox: es una limitacion de infraestructura, no de codigo, y la verificacion de tipos independiente (tsc) termino con cero errores.

Comprobacion	CRM-ALBRA	WHATSPOWER	WHATSPOWER-ULTRA
Instalacion lockfile congelado	PASS (bun, 1043 paq.)	PASS (sin deps)	PASS (sin deps)
Validacion de esquema / tipos	PASS (tsc 0 errores)	N/A (Node nativo)	N/A (Node nativo)
Lint oficial	FAIL pre-existente (328 err., artefactos)	N/A	N/A
Suite oficial de tests	PASS 390/390 (vitest)	PASS 22/22 (+3 secrets)	PASS 19/19
Build de produccion	BLOCKED (memoria sandbox)	N/A	N/A
CI definida	PASS (ci.yml completa)	No existe	No existe
Tests heredados fuera de suite	N/A	2 rotos (import ajeno)	2 rotos (import ajeno / script manual)
Arranque y health check reales	PASS /api/health	PASS /api/health	PASS (Studio + ingesta)

Tabla 2. Resultados de reproducibilidad y pruebas individuales por repositorio.

La bateria vitest de CRM-ALBRA mejoro respecto a la linea base previa de la integracion (386/390): los cuatro fallos heredados relacionados con eco de LLM ya no aparecen contra el codigo publicado. Los cuatro ficheros de tests heredados rotos pertenecen a misiones anteriores e importan rutas absolutas inexistentes; no forman parte de las suites oficiales y se documentan como deuda de higiene sin corregir.

4. Pruebas E2E bidireccionales (Fase C)

El entorno E2E levanto las cinco piezas reales: CRM en puerto 3000, daemon de WhatsApp real en 3002 (sin sesion vinculada, por lo que fisicamente no puede enviar), WHATSPOWER en 3003 con el cliente CRM real configurado, ULTRA en 3004 y un stub fiel del daemon en 3012 para verificar despachos con autenticacion Bearer y registro persistente. Los flujos completos y su evidencia sanitizada estan en la matriz 02 y en la carpeta de evidencias.

Flujo	Pruebas	Resultado	Controles demostrados
1. WHATSPOWER a CRM	A0-A8	8 PASS, 1 controlado	HMAC firmado, cliente source=crm-api, historial correlacionado, idempotencia (deduplicated), 401 firma, 401 replay, 400 incompleto, rechazo controlado de telefono duplicado
2. CRM a WHATSPOWER	B0-B8	10/10 PASS	Webhook Meta con appSecret cifrado AES-256-GCM, entrega del bridge con firma, dedup de wamid, trigger de etapa con outbound persistido (sin envio real), fail-open del CRM, aislamiento multi-tenant real, 401/401/400
3. ULTRA a despacho	C1-C6	12/12 PASS	Guard fisico contra :3002, daemon real 401/400-no-conectado, dedup 3-2 targets, SENT/SENT/COMPLETED, PAUSED_OFF_HOURS, UNCERTAIN_DISPATCH en timeout y en 200 malformado, ingesta de leads con validacion
4. Fallos y recuperacion	D0-D5	9/9 PASS	CRM caido: 200 crmSynced=false en 17 ms sin 500; recuperacion verificada; reinicio de WP con persistencia; daemon fail-closed al arranque; ULTRA sin secret: 401 sin exito falso

Tabla 3. Resumen de la bateria E2E (evidencia completa en evidencias/e2e/).

Dos comportamientos merecen destacarse por su relevancia operativa. Primero, ULTRA nunca convierte un fallo en exito falso: cuando el despacho expira sin confirmacion o el daemon responde con un cuerpo malformado, el item queda en estado UNCERTAIN_DISPATCH y bloquea el reenvio ciego, exactamente el contrato exigido. Segundo, el fail-open del CRM frente a una caida de WHATSPOWER es deliberado y controlado: el webhook de WhatsApp sigue procesando con respuesta 200 y degradacion elegante, y la sincronizacion se recupera sola cuando el servicio vuelve.

5. Seguridad funcional (Fase E)

Control	Prueba ejecutada	Estado
Acceso no autenticado rechazado	B7: POST /api/crm/actions sin Bearer	PASS (401)
Credenciales incorrectas rechazadas	B7 clave invalida; C2/D2 Bearer erroneo; D5 sin secret	PASS (401)
Autorizacion por organizacion	B6: API key de org B sobre cliente de org A	PASS (rechazo)
Firma HMAC validada	A5 inbound WP; B1/B8 webhook Meta; bridge CRM-WP	PASS
Proteccion anti-replay	A6: X-Timestamp con desfase de 400 s	PASS (401)
Idempotencia de eventos y despachos	A2, B3, C3 re-ejecuciones	PASS
Sin secretos en respuestas, errores ni logs	Revision de logs y salidas de las 5 piezas	PASS

Control	Prueba ejecutada	Estado
Fail-closed sin secreto	D4 daemon (exit 1); WP corregido (503); piloto ULTRA (aborta)	PASS tras correcciones
Sin caminos alternativos de saltear controles	Guard :3002 sin allowRealDispatch; transport Mock en WP; daemon sin sesion	PASS
Barreras de envio real activas	C1, C2, B4; piloto C2B bloqueado de fabrica	PASS

Tabla 4. Controles de seguridad funcional verificados mediante ejecucion real.

La superficie de gestion de WHATSPOWER (locks, supresiones, flujos, equipo, plantillas, pagos) no exige autenticacion por diseno pre-existente, bajo el supuesto de red local. Con el fail-closed incorporado hoy, los endpoints sensibles ya no aceptan el valor hardcodeado; no obstante, en produccion los puertos 3003 y 3004 nunca deben quedar expuestos a Internet. Este punto se documenta como hallazgo de diseno (D-09) con mitigation de despliegue, sin reestructurar el plano de gestion completo sin autorizacion.

6. Credenciales, historial Git y rotacion (Fase D)

El escaneo cubrio el arbol de trabajo y el historial completo de los tres repositorios con patrones de tokens de GitHub, claves de IA (incluida NVIDIA), claves de API, contrasenas, secretos de webhook, INTERNAL_API_SECRET y APP_ENCRYPTION_KEY, URLs de base de datos y claves privadas. Los resultados concretos, sin valores, estan en evidencias/escaneo-credenciales.json. El PAT expuesto en el chat no fue reutilizado, reconstruido ni almacenado; se considera comprometido hasta que el propietario confirme su revocacion.

Hallazgo	Ubicacion	Alcance	Accion requerida
Clave NVIDIA (nvapi-) en historial	CRM: scripts/test_cerebros_nvidia.py en 4 commits historicos; ausente en HEAD	Valor publico y recuperable	Rotar la clave (PRO-04); reescritura de historial solo con autorizacion
INTERNAL_API_SECRET hardcodeada antigua	Historial de WP (12 ocurrencias) y ULTRA (16); 0 en HEAD tras correcciones	Valor publico conocido, ya no aceptado por el codigo	Rotacion coordinada (PRO-02)
Secret de desarrollo del webhook	Historial de WP (3); eliminado del codigo hoy	Ya no aceptado (fail-closed)	Cubierto por la rotacion
PAT de GitHub del chat	No esta en arboles ni historiales	Comprometido en conversacion	Revocar y confirmar (PRO-01)
Valores reales en HEAD	0 secretos reales en los tres repos	Limpio	Mantener higiene en futuros commits

Tabla 5. Hallazgos de credenciales en arbol e historial (sin valores).

Se confirmo contra el codigo actual que INTERNAL_API_SECRET la comparten exactamente cuatro procesos: la aplicacion CRM (rutas de WhatsApp y doctor), el daemon Baileys (que no arranca sin ella), WHATSPOWER (autenticacion interna, corregida a fail-closed) y ULTRA (dispatcher y script de piloto). El procedimiento de rotacion coordinada esta preparado en la matriz 03, incluida la advertencia critica sobre APP_ENCRYPTION_KEY: cifra los tokens persistidos en Integration, por lo que su cambio exige descifrar

y re-cifrar los registros antes de sustituir la variable, nunca a ciegas.

7. Defectos encontrados y correcciones efectuadas (Fase H)

ID	Sev.	Repositorio	Defecto	Estado
D-01	P1	WHATSPOWER	Supresiones internas con fallback hardcodeado de INTERNAL_API_SECRET (valor publico): fail-open	CORREGIDO + 4 regresiones
D-02	P1	WHATSPOWER	Inbound webhook con secret de desarrollo por defecto (publico): webhooks falsificables sin configuracion	CORREGIDO (503 fail-closed)
D-03	P2	WHATSPOWER	created_at en segundos en el trigger de etapa frente a milisegundos en el resto: orden temporal corrupto del historial	CORREGIDO + 2 regresiones
D-04	P1	ULTRA	Script de piloto con el mismo fallback hardcodeado	CORREGIDO (aborta sin secret)
D-05	P3	WP + ULTRA	4 tests heredados rotos fuera de las suites oficiales	Documentado
D-06	P3	CRM	package-lock.json desincronizado (CI real usa bun.lock)	Documentado
D-07	P3	CRM	Artefactos de recuperacion commiteados rompen el lint (328 errores)	Documentado
D-08	P3	WP + ULTRA	Sin pipelines de CI	Documentado
D-09	P4	WP	Plano de gestion sin autenticacion (diseno de red local)	Documentado con mitigacion
D-10	P4	WP	Inbound sin firma aceptado si NODE_ENV != production	Documentado (mitigado por D-02)

Tabla 6. Defectos priorizados (detalle completo en matrices/05-defectos-priorizados.md).

Las correcciones se aplicaron unicamente en el alcance autorizado y se validaron re-ejecutando las suites completas: WHATSPOWER 22/22 con la suite de aceptacion CP-01 a CP-11 en verde, ULTRA 19/19 y las seis regresiones nuevas pasando. El test CP-11 codificaba el comportamiento vulnerable y fue actualizado al contrato seguro con una verificacion adicional: hoy el valor hardcodeado historico recibe 401 incluso con secret real configurado. No se altero ningun test para maquillar resultados; los diffs completos de las correcciones acompanan este informe como evidencia.

8. Persistencia, backup y recuperacion (Fase F)

El drill se ejecuto sobre la base de datos sintetica de la campana con la API de backup online de better-sqlite3. La restauracion en una instancia aislada preservo la integridad referencial (integrity_check ok), los recuentos por tabla coincidieron con el momento exacto del backup y la fila marcadora insertada despues de la copia no aparecio en la restauracion, demostrando consistencia puntual. La caida de procesos sin exito falso ya estaba demostrada en la fase E2E con UNCERTAIN_DISPATCH y crmSynced=false.

Paso	Resultado
F1 Consistencia de BD activa	integrity_check=ok; 3 clientes, 1 API key, 2 historiales
F2 Backup online	Creado con la API .backup (segura con WAL)
F3 Modificacion posterior	Fila marcadora insertada tras el backup
F4 Restauracion aislada	integrity_check=ok; recuentos identicos al momento del backup; marcadora ausente
F5 Datos de negocio restaurados	Clientes crm-api y historial conversacional intactos
F6 Eventos pendientes	Tabla de mensajeria compartida restaurada; cobertura por dedup WP y UNCERTAIN_DISPATCH de ULTRA
F0 Hallazgo operativo	Copiar solo el fichero .db con WAL activo pierde transacciones: el backup debe ser online o con checkpoint previo

Tabla 7. Drill de backup y restauracion (evidencia fase-F-backup-restore.txt).

9. Preparacion de produccion y criterios de aceptacion (Fase G)

La documentacion de despliegue existente coincide con el codigo publicado en lo esencial: docker-compose con .env fuera de la imagen, DEPLOY.md con generacion de secretos mediante openssl, manual operativo de WHATSPOWER con orden de arranque y health checks, y volumen propio para la sesion de WhatsApp. WHATSPOWER y ULTRA carecen de Dockerfile, por lo que el plan los despliega con systemd ejecutando Node con strip-types. La matriz 04 detalla servicios, dependencias, variables (solo nombres), puertos, orden de arranque, health checks, logs, backup, actualizacion y rollback.

ID	Criterio para declarar "Produccion Verificada"	Bloqueo actual
P-01	PAT de GitHub revocado y confirmado por el propietario	Sin confirmacion
P-02	INTERNAL_API_SECRET rotada; valor antiguo rechazado con 401	Pendiente de rotacion
P-03	Secret de webhook rotado; firma antigua rechazada	Pendiente de rotacion
P-04	APP_ENCRYPTION_KEY rotada con migracion de datos cifrados	Pendiente (no hacer a ciegas)
P-05	Correcciones de esta campana publicadas en los tres repos	Esperando autorizacion de push
P-06	Despliegue real con HTTPS y health checks verdes	Sin despliegue
P-07	WhatsApp vinculado a cuenta real con verificacion controlada solo al operador	Sin ejecutar

ID	Criterio para declarar "Produccion Verificada"	Bloqueo actual
P-08	Drill de backup/restore ejecutado en el VPS real	Sin ejecutar

Tabla 8. Criterios binarios P-01 a P-08: sin los ocho, no se puede declarar produccion verificada.

10. Bloqueos, pasos del propietario y declaracion final

Todos los bloqueos restantes requieren acciones que solo el propietario puede ejecutar o autorizar. Los procedimientos exactos, paso a paso, estan en matrices/06-procedimientos-propietario.md: revocacion del PAT (PRO-01), rotacion coordinada de secretos con ventana de mantenimiento y migracion de datos cifrados (PRO-02), publicacion de las correcciones tras revision de los diffs (PRO-03), rotacion de la clave NVIDIA (PRO-04), despliegue y verificacion controlada en produccion (PRO-05) y activacion de barreras anti-envio por defecto (PRO-06).

> **Declaracion final.** Sandbox verificado con instancias reales de software: integracion demostrada de extremo a extremo y controles activos. Produccion NO verificada: ninguna prueba de esta campana se ejecuto en el entorno productivo real, y no debe declararse produccion verificada hasta completar P-01 a P-08 con evidencia del VPS. Los tres servicios permanecen con sus barreras de envio real activas y ninguna campaña fue activada durante toda la campana.

El sistema queda en condiciones de avanzar a produccion en cuanto el propietario complete las rotaciones y autorice la publicacion de las correcciones. La re-ejecucion de esta misma campana contra el entorno real, reutilizando los scripts entregados, constituye la via mas rapida y reproducible para obtener la evidencia que exigen los criterios P-06 a P-08.

Anexo A. Inventario de evidencias

Evidencia	Contenido
evidencias/e2e/A-whatspower-crm.txt	Flujo 1 completo: firmado, idempotencia, persistencia CRM, rechazos
evidencias/e2e/B-crm-whatspower.txt	Flujo 2 completo: webhook Meta, bridge, dedup, trigger, fail-open, multi-tenant
evidencias/e2e/C-ultra-daemon.txt	Flujo 3 completo: guard, daemon real, dedup, anti-ban, UNCERTAIN_DISPATCH
evidencias/e2e/D-fallos-recuperacion.txt	Flujo 4 completo: caidas, reinicios, fail-closed, secretos incorrectos
evidencias/crm-vitest-completo.txt	Suite vitest completa de CRM: 390/390 en 61 s
evidencias/crm-build.txt, crm-build2.txt	Build de produccion: compile OK y OOM del sandbox
evidencias/fase-F-backup-restore.txt	Drill de backup online, restauracion aislada e integridad
evidencias/escaneo-credenciales.json	Escaneo de credenciales en arbol e historial (sanitizado, sin valores)
evidencias/diffs-correcciones-*.patch	Diffs completos de las correcciones D-01 a D-04 (sin publicar)

Evidencia	Contenido
matrices/01-07	Matrices detalladas: repos, E2E, credenciales, produccion, defectos, procedimientos, checklist
FINAL_STATUS.md	Dictamen sin ambiguedades en una pagina